

דיווח יזום למערך הסייבר הלאומי (INCD) — פעילות סריקה

כלפי תשתיות Teva Pharmaceutical Industries

סטטוס מסמך: טיוטה לבדיקת המדווח לפני שליחה בפועל ל-INCD/CERT-IL.

1. פרטי המדווח

- שם/איש קשר: נתי שטרן
- דוא"ל: nsh531@gmail.com
- מהות הפנייה: דיווח יזום (Responsible Disclosure) על פעילות בדיקה/סריקה שביצע המדווח כלפי תשתיות דיגיטליות של Teva Pharmaceutical Industries וחברות-בנות שלה, ללא הרשאה חתומה מראש מצד החברה.

2. הצהרת מעמד ההרשאה — חשוב לקרוא לפני כל דבר אחר

לא קיים הסכם התקשרות חתום, חלון בדיקה מאושר, כתובת IP מקור מאושרת, או איש קשר לחירום מטעם Teva עבור הפעילות המתוארת במסמך זה. הפעילות בוצעה כמחקר עצמאי/פרטי, ולא כחלק ממבצע בדיקות חדירה (Penetration Test) מוזמן ומאושר.

מסמך זה נכתב מתוך רצון לגלות באופן יזום ומלא את הפעילות שבוצעה בפועל, כדי לאפשר ל-INCD ו/או ל-Teva להעריך את החשיפה ולנקוט בפעולות הדרושות — ולא כדי להציג את הפעילות כמבצע מורשה. כל ניסוח במסמך זה נשמר עובדתי ומדויק ככל האפשר, כולל בנוגע להיקף הפעילות, כדי לא להטעות את הגורם המקבל.

3. תקציר מנהלים

ב-23.7.2026 בוצעו 315 בקשות HTTP מסוג GET כלפי 21 מארחים (hosts) שונים בתחומי Teva/חברות-בנות שלה (teva.co.il, tevapharm.com, mepha.ch, tevahip.com, tevapharm.eu, ועוד), כל אחד מהם נבדק מול 16 נתיבים הידועים כנקודות כניסה נפוצות לאימות/ניהול-מרחוק/VPN (Exchange OWA/ECP, ADFS, Autodiscover, Citrix, RDWeb, Cisco, Palo Alto GlobalProtect, SharePoint, ASA (+CSCOE+), ועוד). בנוסף בוצעה בעבר (ראו סעיף 5) בקשה בודדת נפרדת כלפי <https://events-new.mepha.ch/remote/login>. **הראיות מצביעות על כך שהריצה נקטעה באמצע (ראו הערת הכיסוי בסעיף 6.2) ולא הגיעה לכלל רשימת ה-33+ הדומיינים המתועדים כמורשים ב-scope.md** — ייתכן שהיקף הפעילות המתוכנן היה גדול מ-315 הבקשות שתועדו בפועל.

הבהרה חשובה: לא הושגו נתונים רגישים, פרטי גישה (credentials), או מידע אישי (PII) כלשהו. מרבית הבקשות נחסמו על ידי מנגנוני הגנה (WAF/CDN) של Teva עצמה — Imperva/Incapsula ו- Cloudflare — או החזירו שגיאות תקניות (404/500). חלק מהתגובות שהוחזרו בקוד 200 הן דפי-ברירת-מחדל גנריים (catch-all) ולא אישור לקיומן של 15-16 מערכות אימות שונות ונפרדות על אותו מארח. פירוט מלא בסעיף 6.

עם זאת, יש לציין בבירור: מדובר בפעילות סריקה אקטיבית, שיטתית ורחבת-היקף כלפי תשתיות ייצור אמיתיות של חברת תרופות בינלאומית, ללא הרשאה — ותגובות ה-WAF (עוגיות `incap_ses`, `X-Info`) מצביעות על כך שסביר מאוד שהפעילות **כבר נרשמה כאירועי אבטחה** במערכות הניטור של Teva, מעבר לאירוע הבודד שכבר תועד קודם לכן.

4. ציר זמן

שעה (UTC)	אירוע
מועד קודם, לא מתועד במדויק	בקשת GET בודדת בוצעה כלפי <code>https://events-new.mepha.ch/remote/login</code> מחוץ לכלי כלשהו של המדווח — הפעלה שהניבה חסימת Incapsula ותיעוד Incident ID (ראו סעיף 5)
2026-07-23 09:13:05	תחילת סבב הסריקה השיטתי (315 בקשות)
2026-07-23 09:24:06	סיום סבב הסריקה השיטתי
2026-07-23 (מועד דיווח)	הכנת מסמך זה

5. האירוע שתועד קודם לכן — `events-new.mepha.ch/remote/login`

לפי תיעוד פנימי שנשמר על ידי המדווח (`pentest-teva/scope.md` במאגר העבודה), בוצעה בקשת GET בודדת, פעילה, כלפי `https://events-new.mepha.ch/remote/login` (עמוד התחברות באתר Mepha, חברת-בת של Teva בשווייץ). הבקשה נחסמה על ידי ה-WAF של Incapsula, ונרשם אירוע אבטחה עם המזהה:

```
incident_id: 3302000180717277597-713775929329321140
```

לא נמצא תיעוד מדויק (timestamp/response headers גולמיים) של הבקשה הזו הספציפית בחומר שנמסר למדווח זה מהמדווח המקורי — המזהה לעיל הוא כל המידע הזמין. **מומלץ למדווח לצרף כל תיעוד גולמי נוסף שברשותו (צילום מסך, לוגים) לפני שליחת המסמך בפועל.**

6. סבב הסריקה השיטתי (315 בקשות, 23.7.2026, 09:13–09:24 UTC)

6.1 מתודולוגיה

כל הבקשות היו מסוג **GET בלבד** (ללא POST/PUT/DELETE), ללא שימוש בפרטי גישה כלשהם (אין הזרקת אישורים, אין ניסיון brute-force), עם קצב מוגבל (rate-limited). הכלי ששימש (tools/teva_pentest_all.py , פקודת adpaths) פותח באופן מכוון כך שכל בקשה תישמר כראיה גולמית (JSON, כולל timestamp, URL, קוד תגובה, headers, גוף התגובה) — כל 315 קבצי הראיה מצורפים תחת pentest-teva/evidence/20260723_adpaths_full_sweep/ , וטבלת סיכום תחת אותה תיקייה (SUMMARY.tsv).

6.2 המארחים שנבדקו — פירוט מלא

מארח	בקשות	פילוח קודי תגובה	הגנת WAF/CDN שזוהתה
dptest.teva.co.il	16	16×500	לא זוהתה
events-new.mepha.ch	16	16×503	Imperva/Incapsula
gml.teva.co.il	16	15×404 1×403	Cloudflare

מארח	בקשות	פילוח קודי תגובה	הגנת WAF/CDN שזוהתה
hcp.teva.co.il	16	,15×200 1×403	Cloudflare
hipuat.tevahip.com	16	16×404	לא זוהתה
login.tevapharm.eu	16	16×503	Imperva/Incapsula
magasinpharmasolutionsteva.ca	16	16×503	Imperva/Incapsula
mepha.ch	16	16×403	Imperva/Incapsula
mon-teva.fr	16	16×403	Imperva/Incapsula
neurologybytes.com.mx	16	16×403	Imperva/Incapsula
nofesh.teva.co.il	17	,16×404 1×200	Imperva/Incapsula (עוגייה Domain=.teva.co.il)
propharma.mepha.ch	16	16×401	Imperva/Incapsula

מארח	בקשות	פילוח קודי תגובה	הגנת WAF/CDN שזוהתה
sfc.tevapharm.com	16	16×200	Imperva/Incapsula
shoptevapharmacysolutions.ca	16	16×503	Imperva/Incapsula
sicor.ch	16	16×404	לא זוהתה
sleonline.co.il	16	16×503	Imperva/Incapsula
styleguide.teva	16	16×503	Imperva/Incapsula
sudocrem.hr	16	16×404	לא זוהתה
supremin.com.hr	16	15×404 1×403	Imperva/Incapsula (עוגייה Domain=.plivazdravlje.hr (
szakmaesuzlet.hu	9 מתוך 16 מתוכננות	7×503 כשל-חיבור 2×	Imperva/Incapsula

מארח	בקשות	פילוח קודי תגובה	הגנת WAF/CDN שזוהתה
tevapharm.com	1 (בדיקת שורש בלבד)	1×200	לא זוהתה בבדיקה זו

הערה חשובה לגבי היקף הכיסוי בפועל: `pentest-teva/scope.md` מתעד רשימת `AUTHORIZED_DOMAINS` של למעלה מ-33 דומיינים בסיסיים (מעבר ל-21 המארחים בטבלה). הבקשה האחרונה בסבב הזה, בשעה 09:24:06 UTC, היא לנתיב ה-11 מתוך 16 המתוכננים על `szakmaesuzlet.hu` (`/citrix/`) — ואין רשומות אחריה. גם `tevapharm.com` נבדק רק בבקשת-שורש בודדת, ללא 16 הנתיבים המלאים. המסקנה הסבירה: **הריצה נעצרה/נקטעה באמצע**, ו-315 הבקשות המתועדות כאן משקפות חלק בלבד מסריקה רחבה יותר שהייתה ככל הנראה מתוכננת על פני כל רשימת ה-`AUTHORIZED_DOMAINS`. יש לקחת זאת בחשבון בהערכת ההיקף האמיתי של הפעילות — ייתכן שהיקפה המתוכנן היה גדול יותר מהמתועד בפועל.

6.3 הנתיבים שנבדקו (16 בכל מארח)

נתיב	מייצג בדרך כלל
<code>/owa/</code>	Outlook Web Access — ממשק ה-webmail של Microsoft Exchange
<code>/ecp/</code>	Exchange Control Panel — ממשק ניהול Exchange
<code>/autodiscover/autodiscover.xml</code>	פרוטוקול הגדרה אוטומטית של חשבונות Exchange
<code>/adfs/ls/</code>	Active Directory Federation Services (SSO) — שירות התחברות מאוחדת
<code>/adfs/services/trust/2005/usernamemixed</code>	נקודת קצה של ADFS לאימות שם-משתמש/סיסמה
<code>/remote/login</code>	עמוד כניסה גנרי לגישה מרחוק/VPN (נפוץ ב-Citrix/F5/Fortinet)
<code>/vpn/index.html</code>	פורטל VPN גנרי
<code>/rdweb/</code>	RD Web Access — גישת Windows Remote Desktop דרך הדפדפן
<code>/citrix/</code>	פורטל Citrix (NetScaler Gateway / XenApp)

נתיב	מייצג בדרך כלל
/certsrv/	שירותי תעודות של Microsoft (Certificate Services)
/_vti_inf.html	חשיפת גרסת SharePoint/FrontPage
/_vti_bin/sitedata.asmx	שירות (SOAP) של Web של SharePoint
/_layouts/15/authenticate.aspx	עמוד אימות 2013 SharePoint ואילך
/_api/web	REST API של SharePoint
/+CSCOE+/login.html	פורטל VPN של Cisco ASA
/global-protect/login.esp	פורטל VPN של Palo Alto GlobalProtect

כל 16 הנתיבים שייכים למשפחת נקודות-כניסה לאימות/ניהול-מרחוק — נבחרו על ידי הכלי כמועמדים לנקודת-דריסה (pivot point) פוטנציאלית לרשת הפנימית, לא באופן אקראי.

6.4 ממצאים טכניים — לפי קטגוריה

א. חסימות WAF/CDN — הרוב המכריע של הבקשות (154 מתוך 315, כ-49%)

- Incapsula/Imperva (mepha.ch, events-new.mepha.ch, login.tevapharm.eu, shoptevapharmacysolutions.ca, magasinpharmasolutionsteva.ca, styleguide.teva, sleonline.co.il ועוד): תגובות 503 עם דף אתגר JavaScript של Incapsula, ועוגיות incap_ses... + אסימוני X-Info — כל אחת מהן היא ככל הנראה **אירוע מתועד במערכת הניטור של Imperva** אצל Teva.
- Cloudflare (gml.teva.co.il): תגובות 403 "Attention Required! | Cloudflare" — דף חסימה סטנדרטי, לא תוכן אמיתי מהאתר.

ב. תגובות 401 — כולן על propha.mepha.ch (16 בקשות)

תגובת Incapsula עצמה ("Rejected by policy (from client)") עם header WWW-Authenticate: Basic realm=login — **אין המדובר בהוכחה לקיומו של פורטל אימות אמיתי וזמין**, אלא בדחיית מדיניות של ה-WAF.

ג. תגובות 200 — לא מהוות אישור לקיומן של 15 מערכות שונות (33 בקשות)

- sfc.tevapharm.com (16 בקשות, כולן 200): כל הנתיבים — כולל /owa/, /citrix/, /global-protect/login.esp — מחזירים את אותו דף התחברות בדיוק, של מוצר בשם **Kiteworks** (פתרון העברת קבצים מאובטחת). זהו דף ברירת-מחדל (catch-all) למסלול לא-קיים, לא אישור לכך ש-OWA/Citrix/GlobalProtect פעילים שם.
- hcp.teva.co.il (15 מתוך 16 בקשות, 200): כל הנתיבים מחזירים את אותו מעטפת אפליקציה

גנרית (בעברית, "he-IL"), מאחורי Cloudflare — סביר שמדובר ב-SPA (Single Page Application) שמחזיר את אותו דף לכל נתיב לא-מוכר. `tevapharm.com` - (עמוד הבית עצמו, בקשה בודדת): תגובת 200 רגילה — האתר הציבורי הרגיל.

ד. תגובות 404 — נתיב לא קיים (94 בקשות)

מארחים כמו `hipuat.tevahip.com`, `sicor.ch`, `sudocrem.hr` וכו' — התנהגות תקנית וצפויה, אינה מהווה ממצא.

ה. שגיאות שער (Gateway) — `dptest.teva.co.il` (16 בקשות, כולן 500)

כל 16 הבקשות ל-`dptest.teva.co.il` החזירו שגיאת SOAP גנרית ("Internal Error") עם header `X-Backside-Transport: FAIL FAIL` — סימן היכר של שער **IBM DataPower**, המצביע על כך שהשער לא הצליח להתחבר לשרת גב (backend) עבור הנתיבים הללו. מידע טכני-אינפורמטיבי בלבד (חשיפת סוג טכנולוגיית השער), ולא חשיפת מידע רגיש.

6.5 מה לא נמצא

- לא הושגו פרטי גישה (usernames/passwords/tokens) מכל סוג.
- לא הושג מידע רפואי, מידע אישי (PII), או מידע עסקי רגיש.
- לא בוצעה כל פעולת כתיבה/שינוי/מחיקה, ולא בוצע ניסיון האקניג פעיל (ניצול פרצה, brute-force, וכד').
- לא נמצאה פרצת אבטחה מאושרת (Confirmed Vulnerability) בחומרה גבוהה — הממצאים הם בעיקרם עדות לכך שמנגנוני ההגנה (WAF/CDN) של Teva פעלו כראוי וחסמו את הפעילות.

7. הערכת חומרה/השפעה

7.1 לפי קטגוריית ממצא טכני

- חשיפת מידע רגיש (Information Disclosure): לא נמצאה.** לא הושג מידע אישי, רפואי, פיננסי, או פרטי גישה מכל סוג — ראו סעיף 6.5.
- עקיפת אימות (Authentication Bypass): לא נמצאה.** תגובות ה-401/403 שהתקבלו הן דחיות תקינות של ה-WAF, לא עדות לעקיפת מנגנון אימות כלשהו.
- חשיפת טכנולוגיה (Technology Fingerprinting): חומרה נמוכה, אינפורמטיבי בלבד.** זוהו: שער **IBM DataPower** (`dptest.teva.co.il`), מוצר **Kiteworks** להעברת קבצים (`nofesh.teva.co.il`), שרתי **IIS/Apache** מאחורי **Incapsula** (`sfc.tevapharm.com`), ואישור ש-`teva` (`supremin.com.hr`), הוא דומיין-על פעיל בבעלות Teva. שימושי לתכנון תקיפה עתידית באופן כללי, אך אינו פגיעות בפני עצמו.
- זמינות (Availability): לא נפגעה.** לא בוצע עומס (load/DoS), אין עדות להשפעה על זמינות מערכת כלשהי — נהפוך הוא, מנגנוני ה-WAF תפקדו כצפוי וחסמו את מרבית הבקשות.
- פרצת אבטחה מאושרת בחומרה גבוהה: לא נמצאה.**

7.2 חומרת הפעילות עצמה (להבדיל מהממצא הטכני)

כאן ההערכה שונה מהותית: סריקה שיטתית של 315 בקשות (ואולי יותר, אילו לא נקטעה — ראו הערת הכיסוי בסעיף 6.2) כלפי +21 מארחי ייצור של חברת תרופות בינלאומית, ממוקדת בנקודות-קצה של אימות/VPN/ניהול-מרחוק, ללא הרשאה, על פני מספר מדינות/רשויות (ישראל, שווייץ, האיחוד האירופי, קנדה, מקסיקו ועוד) — היא הסיכון המרכזי במסמך זה, ואינה תלויה בכך שהתוצאה הטכנית הייתה בלתי-מזיקה. מדובר בפעילות שראוי לדווח עליה במלואה, ושעשויה להיות בעלת משמעות משפטית עבור המדווח בכל אחת מהמדינות שבהן ממוקמות התשתיות שנבדקו.

8. המלצות ל-Teva (אינפורמטיבי)

- לוודא שכל דומיין/תת-דומיין הרשום ל-Teva ולחברות-הבנות שלה מוגן בעקביות באמצעות WAF/CDN (חלק מהמארחים שנבדקו לא היו כלל מאחורי הגנה כזו).
- לבחון האם התנהגות ה-catch-all על `sfc.tevapharm.com` ו-`hcp.teva.co.il` (החזרת אותו תוכן לכל נתיב) חושפת מידע לא-מכוון על טכנולוגיות פנימיות (Kiteworks וכו').
- לבדוק את לוגי ה-WAF (Incapsula/Cloudflare) בטווח הזמנים 2026-07-23 09:13–09:24 UTC ואת האירוע הקודם (סעיף 5) מול כתובת ה-IP שממנה בוצעה הפעילות (לא ידועה למדווח זה).

9. ראיות מצורפות

- `pentest-teva/evidence/20260723_adpaths_full_sweep/` — 315 קבצי JSON גולמיים, אחד לכל בקשה (URL, timestamp, קוד תגובה, headers, גוף תגובה מלא).
- `pentest-teva/evidence/20260723_adpaths_full_sweep/SUMMARY.tsv` — טבלת סיכום של כל 315 הבקשות (זמן, URL, קוד תגובה, גודל גוף, זיהוי WAF/CDN, שם קובץ ראיה).
- `pentest-teva/scope.md` — תיעוד היסטוריית קבלת ההחלטות של המדווח (רקע, לא מסמך הרשאה).

10. הצהרת תום לב

המדווח פועל מרצונו החופשי לגלות פעילות זו באופן יזום, מתוך הכרה בכך שבוצעה ללא הרשאה פורמלית, ומתוך רצון לאפשר ל-INCD ו/או ל-Teva להעריך ולטפל בחשיפה. המדווח לא ניסה להשיג רווח, לגרום נזק, או לפגוע בזמינות המערכות. **מומלץ בחום למדווח להיוועץ בעורך דין בטרם שליחת מסמך זה בפועל**, נוכח היקף הפעילות המתואר.

מסמך זה הוכן על ידי Claude (Anthropic) בהתאם לבקשת המדווח, על בסיס הראיות שנמסרו לו. הוא מהווה טיוטה לבדיקה ולעריכה על ידי המדווח — לרבות מילוי פרטי קשר, צירוף ראיות נוספות, וייעוץ משפטי — בטרם כל שליחה בפועל לגורם רשמי.